

RISKSHIELD

AI-Assisted Risk Management System

Project Technical Report
GENERATIVE AI (PCCCS681)



Project Name	RiskShield
Version	1.0
Report Type	Technical Project Report
Technology Stack	JavaScript, Gemini API, LangGraph, RAG, AWS
Deployment	AWS Amplify (S3, Lambda, DynamoDB)
Date	March 2026

Team Name: PYRO

Ayan Chattopadhyay (Roll No.: 46)

Ayuska Saha (Roll No.: 47)

Amreta Dey(Roll No.: 39)

Astha Nemu(Roll No.: 43)

Table of Contents

1. Executive Summary
2. Project Overview
3. Problem Statement
4. System Architecture
5. Multi-Agent Framework
6. Risk Analysis Features
7. Visualization & Reporting
8. AWS Infrastructure & Deployment
9. Technology Stack
10. Policy Compliance Module
11. The Copilot Agent — Core Novelty
12. Security & Data Privacy
13. Challenges & Solutions
14. Conclusion & Future Prospects

1. Executive Summary

RiskShield is an advanced, AI-driven risk management platform designed to automate the identification, scoring, analysis, and mitigation of enterprise risks across six critical domains: Technical, Cybersecurity, Financial, Marketing, Business, and Operational. By leveraging a sophisticated multi-agent architecture powered by Google Gemini API and LangGraph orchestration, RiskShield transforms complex input documents — Software Requirements Specifications (SRS), Business Requirements Documents (BRD), and Policy Compliance Documents — into comprehensive, actionable risk intelligence.

The platform processes uploaded documents through a pipeline of six specialized AI agents, producing scored risk assessments, probability visualizations, radar charts, mitigation strategies, and policy violation reports — all within an intuitive interface. The system's most innovative feature is its embedded Copilot Agent, which provides contextual query resolution and intelligent suggestions throughout the risk analysis workflow.

Key Highlights

Six-agent AI pipeline | Six risk domains | Gemini API + LangGraph | AWS Amplify deployment | Real-time copilot assistance | RAG-powered document understanding | Risk scoring with visual dashboards

RiskShield is architected for both local development and scalable cloud deployment via AWS Amplify (S3, Lambda, DynamoDB), with a configuration flag (`aws_enabled: true/false`) enabling seamless switching between cloud and local environments — making it accessible for teams at any stage of deployment maturity.

2. Project Overview

2.1 Background & Motivation

Modern enterprises operate in environments of increasing complexity — regulatory pressure, cyber threats, volatile markets, and evolving operational requirements all contribute to a landscape where manual risk assessment is no longer sufficient. Traditional risk management approaches are time-consuming, inconsistent, and often siloed across departments. RiskShield was conceived to address these limitations by bringing AI-driven automation to the entire risk management lifecycle.

2.2 Project Objectives

- Automate multi-domain risk identification from enterprise documents
- Provide quantified risk scores with probability and impact assessments
- Generate actionable mitigation strategies tailored to identified risks
- Validate organizational adherence to policy compliance frameworks
- Deliver rich visual analytics including radar charts, bar graphs, and probability plots
- Offer an intelligent AI Copilot for analyst guidance and query resolution
- Support flexible deployment via AWS cloud or local execution environments

2.3 Target Users

RiskShield is designed for Risk Managers, Chief Information Security Officers (CISOs), Business Analysts, Compliance Officers, Project Managers, and C-Suite executives requiring concise, AI-generated risk briefings across organizational functions.

The screenshot displays the RiskShield web application interface. At the top, a status bar indicates 'GEMINI 2.5 FLASH • FREE • MULTI-AGENT RAG'. The main heading 'RiskShield' is prominently displayed, followed by a subtitle: 'AI-powered risk analysis for SRS & BRD documents. 8 parallel agents • Full visualization dashboard • Copilot included.' Below this, a section for the 'GEMINI API KEY (free at aistudio.google.com)' features a text input field with a masked key. Underneath, three document upload slots are shown, each with a checkmark icon and a 'click to replace' link. The slots are labeled 'SRS TEST 1.pdf', 'BRD TESTS 1.pdf', and 'Compliance Document TEST 1.pdf'. At the bottom, a large blue button labeled 'Run Risk Analysis' is visible.

3. Problem Statement

Enterprise risk assessment traditionally involves significant human effort in reviewing voluminous documentation, applying domain expertise, cross-referencing regulatory requirements, and synthesizing findings into reports. This process is characterized by:

- **Inconsistency:** Different analysts may identify and score risks differently, reducing comparability
- **Latency:** Manual reviews can take days or weeks, delaying risk-informed decision making
- **Coverage Gaps:** Human reviewers may miss risks outside their domain expertise
- **Siloed Analysis:** Technical, cybersecurity, and financial risks are rarely analyzed holistically
- **Policy Drift:** Compliance gaps may go undetected without systematic cross-referencing
- **Limited Accessibility:** Risk insights are often locked in complex reports, inaccessible to stakeholders

The RiskShield Solution

RiskShield addresses all six challenges through its multi-agent AI pipeline, providing consistent, rapid, comprehensive, cross-domain, policy-aware, and accessible risk intelligence — powered by state-of-the-art large language models and retrieval-augmented generation.



4. System Architecture

RiskShield is built on a modular, event-driven architecture that enables clear separation of concerns across its processing pipeline. The system accepts three input document types, processes them through six AI agents orchestrated by LangGraph, and delivers outputs through a multi-modal dashboard.

4.1 High-Level Architecture

INPUT LAYER

SRS Document | BRD Document | Policy Compliance Document

PROCESSING LAYER (LangGraph Orchestration)

Agent 1: Document Parser → Agent 2: RAG Indexer → Agent 3: Risk Analyst

Agent 4: Policy Checker → Agent 5: Mitigation Strategy Agent → Agent 6: Copilot Agent

OUTPUT LAYER

Risk Scores | Radar Charts | Bar Graphs | Mitigation Plans | Policy Violations | Copilot Interface

INFRASTRUCTURE LAYER

AWS Amplify | S3 (Document Storage) | Lambda (Processing) | DynamoDB (Results) | Local Mode

4.2 Input Document Schema

The system accepts three primary document types. Each document type activates specific agents and informs different dimensions of the risk analysis:

- **Software Requirements Specification (SRS):** Drives technical risk identification, requirement conflicts, and cybersecurity exposure analysis
- **Business Requirements Document (BRD):** Informs business, financial, marketing, and operational risk assessment
- **Policy Compliance Document:** Enables policy validation, regulatory gap analysis, and compliance scoring

5. Multi-Agent Framework

RiskShield's processing pipeline is powered by six specialized AI agents orchestrated using LangGraph, a graph-based framework for building stateful multi-agent workflows. Each agent is designed with a distinct responsibility, enabling parallelism, traceability, and modularity in the analysis pipeline.

Agent Name	Role	Input	Output
Document Parser	Extracts and normalizes raw content from uploaded documents	SRS, BRD, Policy Docs	Structured text chunks, metadata
RAG Indexer	Indexes parsed content into a vector store for semantic retrieval	Parsed document chunks	Indexed vector embeddings
Risk Analyst	Identifies and scores risks across all six domains	Indexed vectors + prompts	Risk scores, risk catalog
Policy Checker	Cross-references identified risks against policy compliance documents	Risk catalog + policy doc	Violation flags, compliance score
Mitigation Strategy Agent	Generates actionable mitigation recommendations per risk	Risk catalog + context	Mitigation plans per risk
Copilot Agent	Provides conversational Q&A and suggestions throughout workflow	User query + full context	Natural language guidance

5.1 Agent 1: Document Parser

The Document Parser serves as the entry point of the RiskShield pipeline. It accepts raw uploaded files (PDF, DOCX, or text) and performs structured extraction using Gemini API's document understanding capabilities. The parser identifies section boundaries, extracts requirements, constraints, and process descriptions, and normalizes content into JSON-structured chunks for downstream processing. Metadata such as document type, section headers, and page references are preserved to maintain traceability throughout the analysis.

5.2 Agent 2: RAG Indexer

The Retrieval-Augmented Generation (RAG) Indexer transforms parsed document chunks into dense vector embeddings using Gemini's embedding models. These embeddings are stored in a local or cloud-based vector index. During risk analysis, the RAG Indexer retrieves the most semantically relevant document passages in response to risk-identification queries, ensuring that the Risk Analyst agent operates on grounded, contextually accurate information rather than relying solely on model parametric knowledge.

5.3 Agent 3: Risk Analyst

The Risk Analyst is the core intelligence engine of RiskShield. Powered by the Gemini API and augmented by RAG-retrieved context, it systematically evaluates risk across six domains: Technical, Cybersecurity, Financial, Marketing, Business, and Operational. For each identified risk, the agent produces a structured risk record including: risk title, description, affected domain, likelihood score (0–10), impact score (0–10), composite risk score, risk level classification (Low/Medium/High/Critical), and supporting evidence from source documents.

5.4 Agent 4: Policy Checker

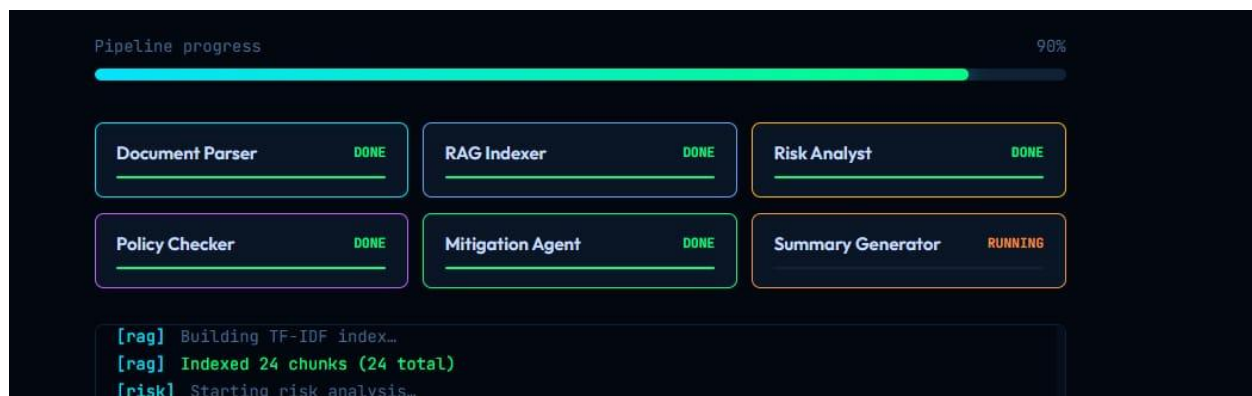
The Policy Checker cross-references the Risk Analyst's output against the uploaded Policy Compliance Document. Using semantic similarity and rule-based matching, it identifies where identified risks constitute policy violations or compliance gaps. Outputs include a violation catalog with severity ratings, specific policy clauses breached, and a composite policy compliance score. This agent is particularly valuable for regulated industries such as healthcare, finance, and government.

5.5 Agent 5: Mitigation Strategy Agent

The Mitigation Strategy Agent generates tailored risk mitigation recommendations for each risk identified by the Risk Analyst. It produces multi-tiered strategies including immediate remediation actions, medium-term controls, and long-term preventive measures. Each strategy is prioritized by urgency and estimated effort, providing risk managers with a clear, implementable roadmap for risk reduction.

5.6 Agent 6: Copilot Agent (Core Novelty)

The Copilot Agent represents the most innovative feature of RiskShield. Operating as an always-available intelligent assistant throughout the platform, it allows users to ask contextual questions about any aspect of the analysis — from clarifying specific risk scores to requesting elaboration on mitigation strategies or querying policy implications. Detailed discussion of this agent is provided in Section 11.



6. Risk Analysis Features

RiskShield analyzes risks across six distinct domains, each covering a comprehensive set of sub-categories relevant to modern enterprise operations. The Risk Analyst agent produces quantified scores and classifications for each domain.

6.1 Risk Domains

Risk Category	Description	Score	Level
Technical Risk	Architecture flaws, scalability limitations, integration failures, performance bottlenecks	0–10	High
Cybersecurity Risk	Data breaches, unauthorized access, vulnerability exposure, API security gaps	0–10	High
Financial Risk	Budget overruns, revenue shortfalls, cost estimation errors, cash flow risks	0–10	Medium
Marketing Risk	Brand exposure, market fit failures, customer acquisition risks, campaign failures	0–10	Medium
Business Risk	Strategic misalignment, competitive threats, partnership failures, regulatory non-compliance	0–10	High
Operational Risk	Process failures, supply chain disruptions, workforce risks, vendor dependencies	0–10	Medium

6.2 Risk Scoring Methodology

Each identified risk is scored using a composite formula that considers both likelihood and impact dimensions:

Risk Score Formula

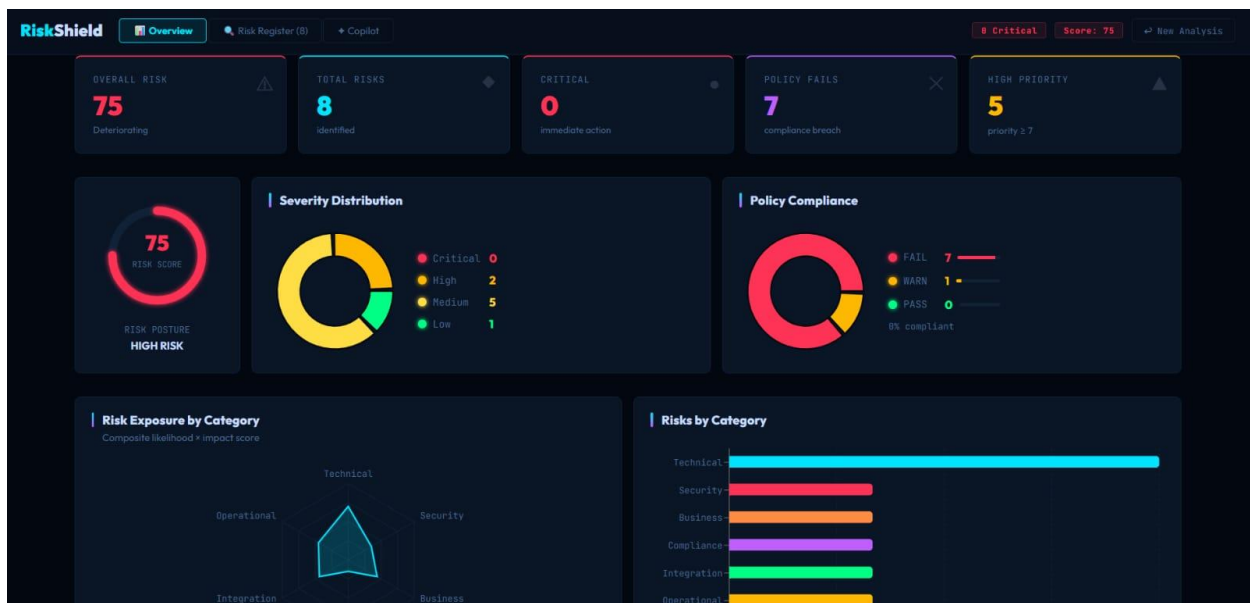
Composite Risk Score = (Likelihood Score × 0.4) + (Impact Score × 0.6) Risk Level Classification: Low (0–3.0) | Medium (3.1–5.5) | High (5.6–7.5) | Critical (7.6–10.0)

The weighted formula intentionally assigns greater weight to impact (0.6) than likelihood (0.4), reflecting the enterprise risk management principle that high-impact, low-probability risks (such as data breaches or financial fraud) must be prioritized over frequent but manageable low-impact events.

6.3 Risk Output Structure

For each identified risk, RiskShield produces a structured record containing the following fields:

- Risk ID: Unique identifier for tracking and referencing
- Domain: One of six categories (Technical, CySec, Financial, Marketing, Business, Operational)
- Risk Title: Concise descriptor of the risk
- Description: Detailed narrative explaining the risk and its context
- Likelihood Score: Probability of occurrence (0–10)
- Impact Score: Severity of consequences if risk materializes (0–10)
- Composite Risk Score: Weighted aggregate score
- Risk Level: Low | Medium | High | Critical classification
- Source Reference: Traceability back to source document section
- Mitigation Strategies: Linked recommendations from Mitigation Agent



7. Visualization & Reporting

A defining strength of RiskShield is its rich visualization layer, which transforms complex risk data into intuitive, decision-ready visual formats. The platform generates multiple chart types that collectively provide both summary-level and drill-down perspectives on organizational risk.

7.1 Radar Charts — Risk Domain Overview

The Radar (Spider) Chart provides a holistic view of risk exposure across all six domains on a single visual. Each axis of the hexagonal chart represents one risk domain, and the plotted polygon's shape immediately communicates which domains carry the highest risk burden.

Multiple radar overlays can represent different time periods or project phases, enabling trend comparison.

Radar Chart Insight

A radar chart skewed toward the Cybersecurity and Technical axes (larger polygon area on those axes) immediately signals to the analyst that the organization's primary risk exposure lies in digital infrastructure — enabling targeted resource allocation without requiring a detailed read of the full risk register.

7.2 Risk Score Bar Charts

Horizontal and vertical bar charts display individual risk items ranked by composite score. Color-coded bars (green for Low, yellow for Medium, orange for High, red for Critical) provide instant visual prioritization. The bar chart view supports domain-level filtering, allowing analysts to focus on a single risk category or view the full cross-domain landscape.

7.3 Probability & Impact Matrix

The classic 2x2 probability-impact scatter plot positions each identified risk on a grid where the X-axis represents likelihood and the Y-axis represents potential impact. Quadrant colorization (green bottom-left to red top-right) enables immediate triage of risks requiring urgent attention versus those suitable for monitoring.

7.4 Probability Distribution Visuals

For high-scoring risks, RiskShield generates probability distribution curves that represent the range of possible risk materialization scenarios. These visualizations help risk managers understand not just a single-point risk score, but the full distribution of potential outcomes — supporting scenario planning and contingency budgeting.

7.5 Policy Violation Summary

A dedicated visualization panel presents policy compliance outcomes as a compliance scorecard with gauge charts showing overall compliance percentage, flagged violation counts by severity, and a timeline view showing when policy gaps were introduced relative to document versions.

7.6 Mitigation Strategy Dashboard

Mitigation recommendations are presented in a structured card-based layout, each card containing the risk reference, strategy description, priority level, estimated implementation effort (Low/Medium/High), and expected risk reduction percentage. A progress tracker allows teams to mark mitigation items as In Progress, Completed, or Deferred.

8. AWS Infrastructure & Deployment

RiskShield is engineered for production-grade cloud deployment via AWS Amplify, with a thoughtfully designed configuration system that enables developers and teams to run the platform locally without any cloud dependency during development or testing phases.

8.1 AWS Configuration Flag

aws_enabled Configuration Flag

aws_enabled: true → Full AWS deployment (S3 + Lambda + DynamoDB) aws_enabled: false → Local mode (file system storage + local processing) This flag enables zero-friction local development while maintaining production-identical code paths for cloud deployment.

8.2 AWS Service Roles

Component	Technology / Tool	Purpose
Document Storage	Amazon S3	Stores uploaded SRS, BRD, and policy documents with versioning and encryption at rest
Agent Processing	AWS Lambda	Serverless execution of all six AI agents with auto-scaling and per-invocation billing
Result Persistence	Amazon DynamoDB	NoSQL storage for risk analysis results, session state, and copilot conversation history
Application Hosting	AWS Amplify	Frontend hosting, CI/CD pipeline, environment management, and custom domain support
API Gateway	AWS API Gateway	RESTful API routing from frontend to Lambda agent functions
Authentication	AWS Cognito (Optional)	User authentication and access control for multi-tenant deployments

8.3 Deployment Architecture

The RiskShield deployment follows a serverless microservices pattern. The React/JavaScript frontend is hosted on AWS Amplify's CDN-backed infrastructure. Document uploads from the browser are routed to an S3 bucket via pre-signed URLs (bypassing Lambda for large file transfers). Lambda functions are invoked asynchronously for each agent step, with DynamoDB storing intermediate and final results. This architecture provides near-infinite horizontal scaling while maintaining low operational costs through Lambda's pay-per-invocation model.

8.4 Local Development Mode

When `aws_enabled` is set to `false`, RiskShield uses the local filesystem for document storage, in-process execution for agent orchestration (via LangGraph running on Node.js), and a local JSON-file-based store for result persistence. This enables full functionality for individual developers and small teams without requiring AWS account setup or incurring cloud costs during prototyping phases.

```

.env .env.example X JS geminiClient.js .gitignore
.env.example
5
6 VITE_GEMINI_API_KEY=
7 VITE_GEMINI_MODEL=gemini-2.5-flash-lite
8 VITE_GEMINI_TEMPERATURE=0.15
9 VITE_RAG_CHUNK_SIZE=500
10 VITE_RAG_CHUNK_OVERLAP=60
11 VITE_RAG_TOP_K=7
12 VITE_AGENT_STAGGER_POLICY_MS=1200
13 VITE_AGENT_STAGGER_MITIGATION_MS=2400
14 VITE_AGENT_SUMMARY_DELAY_MS=1000
15
16 # — AWS Toggle (the one variable that controls everything) —
17 VITE_USE_AWS=true
18
19 # — AWS values (only needed when VITE_USE_AWS=true) —
20 VITE_AWS_LAMBDA_URL=
21 VITE_AWS_S3_BUCKET=riskshield-reports
22 VITE_AWS_DYNAMO_TABLE=riskshield-sessions
23 VITE_AWS_REGION=us-east-1
24
25 VITE_APP_NAME=RiskShield
26 VITE_APP_VERSION=1.0.0
27
56 export async function runPipeline({ apiKey, srsFile, brdFile, policyFile, onLog, onProgress, onS
168 (async () => {
169   try {
170     await sleep(AGENT_TIMING.policyStagger);
171     const res = await callGemini(
172       apiKey,
173       POLICY_SYS,
174       `RISKS:\n${polInput}\n\nPOLICY CONTEXT:\n${polCtx}`,
175       true
176     );
177     const arr = Array.isArray(res) ? res : [];
178     logAndBuffer("pol", `✓ Policy check complete (${arr.length} results)`, "success");
179     return arr;
180   } catch (e) {
181     logAndBuffer("pol", `✗ ${e.message}`, "error");
182     return [];
183   }
184 })(),
185
186 (async () => {
187   try {
188     await sleep(AGENT_TIMING.mitigationStagger);
189     const res = await callGemini(
190       apiKey,
191       MITIGATION_SYS,
192       `RISKS:\n${mitiInput}`,
193       true
194     );
195     const arr = Array.isArray(res) ? res : [];
196     logAndBuffer("mit", `✓ Mitigation strategies generated (${arr.length} results)`, "success");
197     return arr;

```

9. Technology Stack

RiskShield is built on a modern, JavaScript-first technology stack that prioritizes developer productivity, AI capability, and cloud-native deployment. Each technology was selected to address specific requirements of the multi-agent AI risk management use case.

Component	Technology / Tool	Purpose
Frontend Framework	JavaScript (React)	Component-based UI for document upload, risk dashboard, and copilot interface
AI Model	Google Gemini API	Powers all six agents with large language model reasoning, document understanding, and generation
Agent Orchestration	LangGraph	Graph-based state machine for managing multi-agent workflows, agent transitions, and shared state
Retrieval System	RAG (Custom)	Vector-based document retrieval ensuring agents operate on relevant, grounded context
Cloud Platform	AWS Amplify	Managed hosting, CI/CD, and backend service integration
Object Storage	Amazon S3	Scalable, durable document and asset storage
Serverless Compute	AWS Lambda	On-demand execution of agent logic without server management overhead
Database	Amazon DynamoDB	Low-latency NoSQL persistence for risk results and session management
Configuration	Environment Variables (.env)	Manages aws_enabled flag and API keys across environments
Package Management	npm / Node.js	Dependency management and local development tooling

9.1 LangGraph Integration

LangGraph serves as the orchestration backbone of RiskShield's multi-agent pipeline. It enables the definition of agent interactions as directed graphs, where each node represents an agent and edges represent data flow and conditional routing. This architecture provides several advantages: agents can be executed in parallel where dependencies permit (e.g., Risk Analyst and Policy Checker can run concurrently after RAG indexing); the graph state is persisted at each step,

enabling resumability; and conditional edges allow dynamic routing (e.g., skipping Policy Checker if no policy document is uploaded).

9.2 Gemini API Integration

The Google Gemini API is invoked by multiple agents throughout the pipeline. The Document Parser uses Gemini's long-context capabilities to process full-length enterprise documents. The Risk Analyst uses Gemini's reasoning capabilities with structured output prompting to generate JSON-formatted risk records. The Mitigation Strategy Agent leverages Gemini's generation capabilities with chain-of-thought prompting. The Copilot Agent uses multi-turn conversation with injected context to maintain session-aware dialogue.

10. Policy Compliance Module

The Policy Compliance Module is a dedicated subsystem within RiskShield that cross-references identified risks against organizational policy documentation, regulatory frameworks, and compliance standards. It is activated when a Policy Compliance Document is included in the input and is processed by Agent 4 (Policy Checker).

10.1 Policy Violation Detection

The Policy Checker performs semantic matching between each risk record in the risk catalog and the clauses, requirements, and prohibitions defined in the uploaded policy document. For each match, the agent determines whether the identified risk represents a policy violation, a compliance gap, or merely a noted consideration. Violations are classified by severity:

- Critical Violation: Direct contravention of a mandatory policy requirement
- Major Violation: Non-compliance with a significant policy provision
- Minor Violation: Partial or indirect conflict with policy guidance
- Advisory: Risk that, while not a violation, warrants attention under policy spirit

10.2 Compliance Scoring

A composite Policy Compliance Score (0–100%) is calculated based on the number and severity of violations relative to the total number of policy requirements assessed. This score provides a single-number indicator of the organization's current compliance posture as revealed by the uploaded documents.

Compliance Score Formula

Compliance Score = $100 - [(Critical \times 25 + Major \times 15 + Minor \times 5 + Advisory \times 1) / Total \text{ Policy Requirements} \times 100]$ A score above 85% is considered Compliant. 70–85% requires attention. Below 70% indicates significant compliance gaps.

10.3 Policy Violation Report

The Policy Violation Report generated by this module includes a violation summary table, detailed narratives for each violation, specific policy clause references, recommended remediation steps, and an estimated time-to-remediate for each violation. This report is designed to be directly shareable with compliance officers and legal teams.

The screenshot displays the RiskShield interface for policy violation reports. It features a top navigation bar with filters (All, Critical, High, Medium, Low) and a risk count (8 risks). The main content area shows a list of risks with details for R-001 and R-002.

R-001: Incomplete or missing SRS/BRD documentation
 Category: Technical, Severity: High, Score: 6, Policy: FAIL, Priority: P:9
 The provided excerpts are heavily encoded and lack clear textual content, indicating potential gaps or issues with the SRS/BRD documentation itself. This could lead to misunderstandings and development errors.
 Evidence: The document is primarily composed of PDF object streams and encoded data, with very little human-readable text.
 Mitigation: Implement a mandatory review process for all SRS/BRD documents before development begins. Assign a dedicated technical writer to ensure completeness.
 Project Management: Before release, Effort: High
 Policy / Compliance: The document is unreadable, preventing verification of SRS/BRD completeness. ISO 27001 A.8.2.3

R-002: Ambiguous requirements due to poor formatting
 Category: Technical, Severity: Medium, Score: 4, Policy: FAIL, Priority: P:7
 The heavily encoded nature of the document makes it difficult to extract and interpret requirements accurately. This ambiguity can lead to incorrect implementation.
 Evidence: The document content is largely unreadable due to PDF encoding and stream data.
 Mitigation: Establish a standardized template for requirements documentation. Conduct training sessions for all team members on proper formatting and clarity.
 Business Analyst Team, Sprint 1, Effort: Medium
 Policy / Compliance: The document's unreadable format inherently creates ambiguous requirements. ISO 27001 A.8.2.3

R-003: Potential for data corruption during processing
 Category: Technical, Severity: Medium, Score: 3, Policy: WARN, Priority: P:8

```

33 export const POLICY_SYS = `You are a compliance officer. You receive a JSON array of risks and
34 Output a JSON array where each item maps one risk to its compliance status.
35 No markdown, no explanation, JSON array only.
36
37 Each object must have EXACTLY these keys:
38 {
39   "id": "R-001",
40   "policy_status": "PASS" | "WARN" | "FAIL",
41   "policy_note": "One sentence explaining the status.",
42   "regulation": "Relevant standard e.g. GDPR Art.32, ISO 27001, OWASP Top10"
43 }
44
45 Rules:
46 - Every risk ID from the input must appear exactly once in the output.
47 - Keep all string values under 120 characters.
48 - Output the complete JSON array, no truncation.`;
  
```

11. The Copilot Agent — Core Novelty

Project Novelty Statement

The Copilot Agent is the defining innovation of RiskShield. Unlike traditional risk management tools that produce static reports, RiskShield's Copilot Agent creates a dynamic, conversational interface that democratizes access to complex risk intelligence — enabling any stakeholder, regardless of technical background, to query, understand, and act on risk data in natural language.

11.1 What the Copilot Agent Does

The Copilot Agent (Agent 6) is an always-available conversational AI assistant embedded throughout the RiskShield interface. Powered by the Gemini API with full access to the session's analysis context — including all identified risks, mitigation strategies, policy violations, and source documents — it allows users to:

- Ask natural language questions about specific risks: 'Why is the cybersecurity risk score so high?'
- Request elaboration on mitigation strategies: 'Can you give more detail on how to implement the data encryption recommendation?'
- Explore policy implications: 'Which specific policy clauses are violated by Risk ID 007?'
- Receive proactive suggestions: 'Based on the analysis, what should we prioritize this sprint?'
- Compare risks across domains: 'How does our financial risk compare to the operational risk this quarter?'
- Generate stakeholder-ready summaries: 'Write an executive summary of the top five risks for the board presentation'

11.2 Technical Implementation

The Copilot Agent uses a multi-turn conversation model with injected system context. At the start of each session, the full risk analysis results (risk catalog, mitigation plans, policy violations) are serialized into the agent's context window. User queries are appended to the conversation history, and Gemini generates context-aware responses. The LangGraph state machine maintains copilot conversation history as a separate state node, ensuring it can reference any prior exchange in the session.

11.3 Why the Copilot is Innovative

Most AI-assisted risk tools either generate a static document or provide a basic search interface. RiskShield's Copilot Agent goes further by combining three capabilities that are rarely unified: deep context awareness of the full analysis, multi-turn conversational memory, and proactive suggestion generation. This enables a fluid workflow where the analyst and the AI collaborate in real time — the AI doesn't just answer questions, it participates in the risk management process as an intelligent partner.

11.4 Copilot Use Cases

In practice, the Copilot Agent serves several distinct user populations within an organization:

- Technical Teams: Query specific technical risks and receive code-level or architecture-level mitigation guidance
- Executive Stakeholders: Request plain-language summaries and strategic implications without reading detailed reports
- Compliance Officers: Explore policy violations interactively, testing hypothetical remediation scenarios

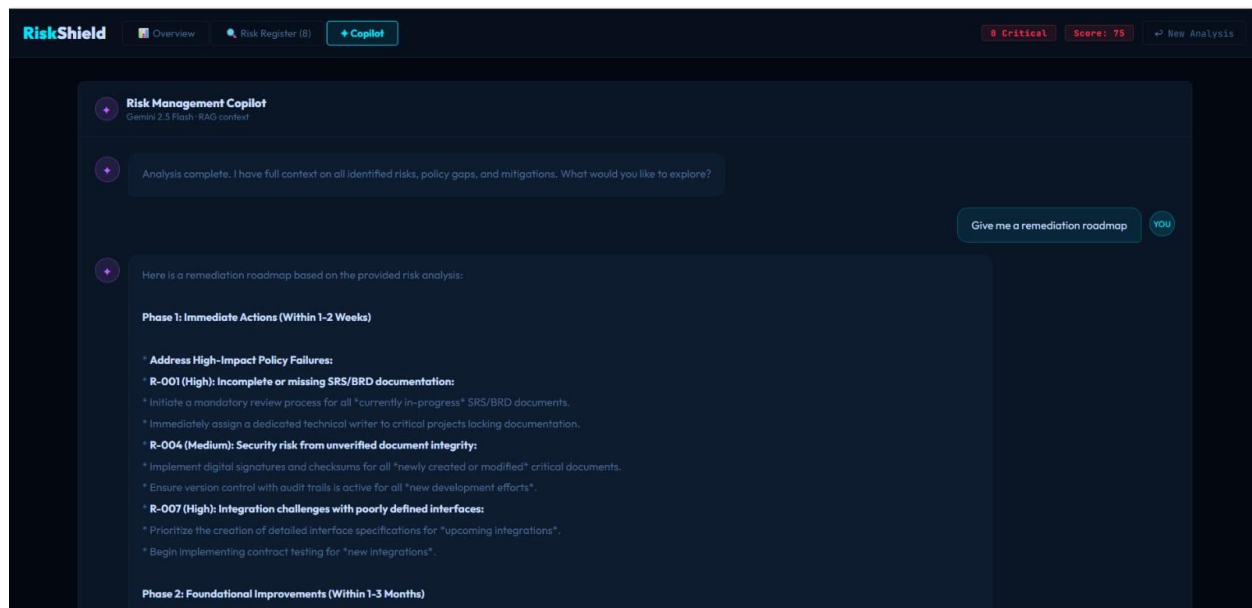
- Project Managers: Track which mitigation strategies are highest priority and estimate resource requirements

```
export const COPILOT_SYS = (riskSummary, ragContext) => `You are a senior risk management copilot w

RISK REGISTER:
${riskSummary}

RELEVANT DOCUMENT CONTEXT (via RAG):
${ragContext}

Answer concisely and practically. Reference risk IDs when relevant. Use bullet points for lists.`;
```



12. Security & Data Privacy

Given that RiskShield processes sensitive enterprise documents containing business requirements, system specifications, and compliance information, security and data privacy are foundational design principles rather than afterthoughts.

12.1 Data Handling

- All uploaded documents are encrypted in transit (TLS 1.3) and at rest (AES-256 via S3 server-side encryption)
- Documents are processed ephemerally by Lambda functions and are not retained in compute memory beyond the processing window
- DynamoDB stores only structured analysis results, not raw document content
- API keys (Gemini API) are managed via AWS Secrets Manager and environment variables, never exposed in client-side code

12.2 Access Control

- AWS IAM policies enforce least-privilege access for Lambda functions to S3 and DynamoDB
- Optional Cognito integration supports user authentication and role-based access control
- S3 bucket policies prevent public access to uploaded documents

12.3 Local Mode Privacy

In local mode (`aws_enabled: false`), all processing occurs on the developer's machine. No data is transmitted to AWS services. Gemini API calls are the only external data transmission, governed by Google's API terms of service and data processing agreements.

The screenshot displays the AWS Amplify console interface. At the top, the breadcrumb navigation shows 'All apps > Ai_Powered_Project_Risk_Management_System: Overview'. The left sidebar contains a menu with 'Hosting' selected, showing options like 'Access control', 'Build notifications', 'Build settings', 'Custom domains', 'Custom headers and cache', 'Environment variables', 'Firewall', 'Previews', 'Rewrites and redirects', and 'Secrets'. Below this are 'Monitoring' and 'App settings'. The main content area is titled 'Get to production' and shows a progress bar for '0 of 3 steps complete'. The steps are: 1. Add a custom domain (with a button 'Add custom domain'), 2. Enable firewall protections (with a button 'Enable firewall'), and 3. Connect new branches (with a button 'Connect a new branch'). Below the steps, there is a 'Branches' section with a search bar and an '+ Add branch' button. It lists the 'main' branch as 'Deployed' with a green checkmark, marked as the 'Production branch'. Below the branch list, there is a table with columns for 'Domain', 'Last deployment', and 'Last commit'. The 'Domain' is 'https://main.d3ak6zf3zacoum.amplifyapp.com', 'Last deployment' is '4 hours ago', and 'Last commit' is 'fix: stable Gemini model and r... / Ai_Powered_Project_Risk_Management_System:main'. At the bottom of the console, there is a dark bar with the AWS logo, a search bar, and a '[Alt+S]' shortcut. Below this bar, the 'AWS Amplify' logo is visible. The 'All apps' section shows a search bar and a list of applications. The first application is 'Ai_Powered_Project_Risk_Management_System', which is 'Deployed' with a green checkmark. Below the application name, there is a table with columns for 'Prod branch', 'Last update', and 'Firewall protections'. The 'Prod branch' is 'main', 'Last update' is '4 hours ago', and 'Firewall protections' is 'Not enabled'.

13. Challenges & Solutions

Building RiskShield presented several technical and design challenges. This section documents the key challenges encountered and the solutions implemented.

Challenge	Solution Implemented
Coordinating six agents without race conditions	LangGraph directed graph with explicit state transitions and dependency edges ensures sequential processing where required
Grounding Gemini responses in document content	RAG pipeline retrieves top-k semantically relevant chunks before each risk analysis query, reducing hallucination
Balancing AWS and local environments	Single <code>aws_enabled</code> boolean flag with adapter pattern abstracts storage and compute differences behind a common interface
Consistent risk scoring across diverse document types	Structured output prompting with JSON schema validation ensures uniform risk record format regardless of input variation
Copilot context window management	Summarization of prior analysis results into compact context injection prevents exceeding Gemini's context window limits
Cold start latency on Lambda	Lambda provisioned concurrency for the most frequently invoked agents (Document Parser, Risk Analyst) reduces cold start impact

14. Conclusion & Future Prospects

14.1 Conclusion

RiskShield represents a meaningful advancement in the application of AI to enterprise risk management. By combining a multi-agent architecture, retrieval-augmented generation, a powerful language model, and an intuitive visualization layer, the platform delivers comprehensive, consistent, and actionable risk intelligence at a fraction of the time and cost of traditional manual assessment approaches.

The six-agent pipeline — Document Parser, RAG Indexer, Risk Analyst, Policy Checker, Mitigation Strategy Agent, and Copilot Agent — each contributes a distinct and indispensable layer of intelligence to the system. Together, they cover the full arc from raw document ingestion to analyst-guided insight extraction. The AWS Amplify deployment architecture ensures that RiskShield is not merely a research prototype but a production-ready system capable of serving enterprise workloads at scale.

Most significantly, the Copilot Agent introduces a genuinely novel interaction paradigm to risk management tooling. By making the full depth of AI-generated risk analysis conversationally accessible, RiskShield transforms risk management from a specialist activity into an organization-wide capability — one where every stakeholder can engage with risk data at the level of detail appropriate to their role.

14.2 Future Prospects

RiskShield's architecture is designed for extensibility. The following future development directions represent both near-term enhancements and longer-term strategic evolutions of the platform:

Company-Specific Customization

A future version of RiskShield will enable deep customization of the risk analysis pipeline to match a specific organization's industry, risk appetite, and internal risk taxonomy. Companies in financial services will have pre-configured risk frameworks aligned with Basel III or SOX requirements; healthcare organizations will be calibrated to HIPAA; technology companies to SOC 2. This domain specialization will dramatically improve the relevance and accuracy of generated risk records.

Organizational Fame & Reputation Risk Module

As organizations increasingly operate in a public-facing environment shaped by social media and real-time news cycles, reputational risk is increasingly significant. A planned Reputation Risk Module will integrate with news APIs and social sentiment analysis to provide a real-time layer of reputational risk assessment layered onto the existing six-domain framework — giving RiskShield a uniquely comprehensive risk picture.

Environmental Conditions Awareness

Future iterations will incorporate macro-environmental risk inputs including geopolitical risk indices, climate risk assessments (physical and transition risks aligned with TCFD frameworks), and economic indicators. These inputs will allow RiskShield to contextualize identified risks against prevailing environmental conditions — for example, flagging supply chain risks as elevated during periods of heightened geopolitical tension.

Regional Customer & Market Customization

RiskShield will expand to support regional regulatory frameworks and customer profile customization. Organizations operating in the EU will benefit from GDPR-aligned compliance checking; those in India from RBI and SEBI compliance modules; those in the Middle East from relevant regional frameworks. Customer profile customization will allow risk weightings to be adjusted based on the organization's primary customer demographics — for example, increasing consumer data risk weightings for B2C companies.

Continuous Risk Monitoring

Rather than a single-session analysis, future RiskShield versions will support continuous risk monitoring by integrating with document version control systems (Git, SharePoint) and triggering re-analysis whenever input documents are updated. This enables a living risk register that evolves with the organization's documents rather than becoming stale post-publication.

Collaborative Risk Management

Multi-user collaboration features — including risk ownership assignment, comment threads on individual risk records, approval workflows for mitigation strategies, and role-based dashboards — will transform RiskShield from an individual analyst tool into an organization-wide risk governance platform.

Expanded LLM Support

While the current implementation leverages the Google Gemini API, the architecture is model-agnostic. Future versions will support configurable model selection, enabling organizations to use Claude, GPT-4, or locally hosted open-source models (Llama, Mistral) depending on their data privacy, cost, and capability requirements.

Strategic Vision

RiskShield is positioned to evolve from a powerful point-solution for AI-assisted risk analysis into a comprehensive enterprise risk intelligence platform — one that is continuously aware, deeply customized, broadly collaborative, and genuinely intelligent. Its foundation in multi-agent AI, RAG, and conversational copilot interaction gives it the architectural headroom to grow with the organizations it serves.